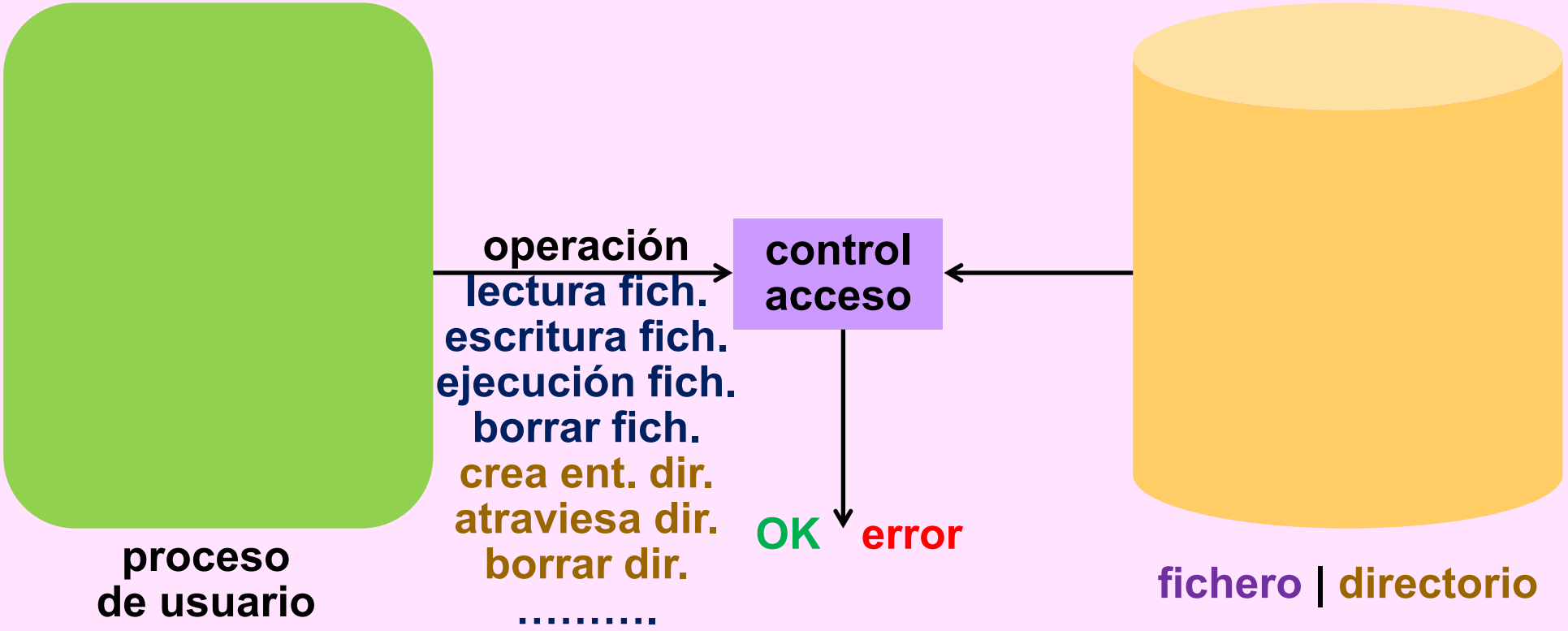
PROTECCIÓN: CONTROL DE ACCESO

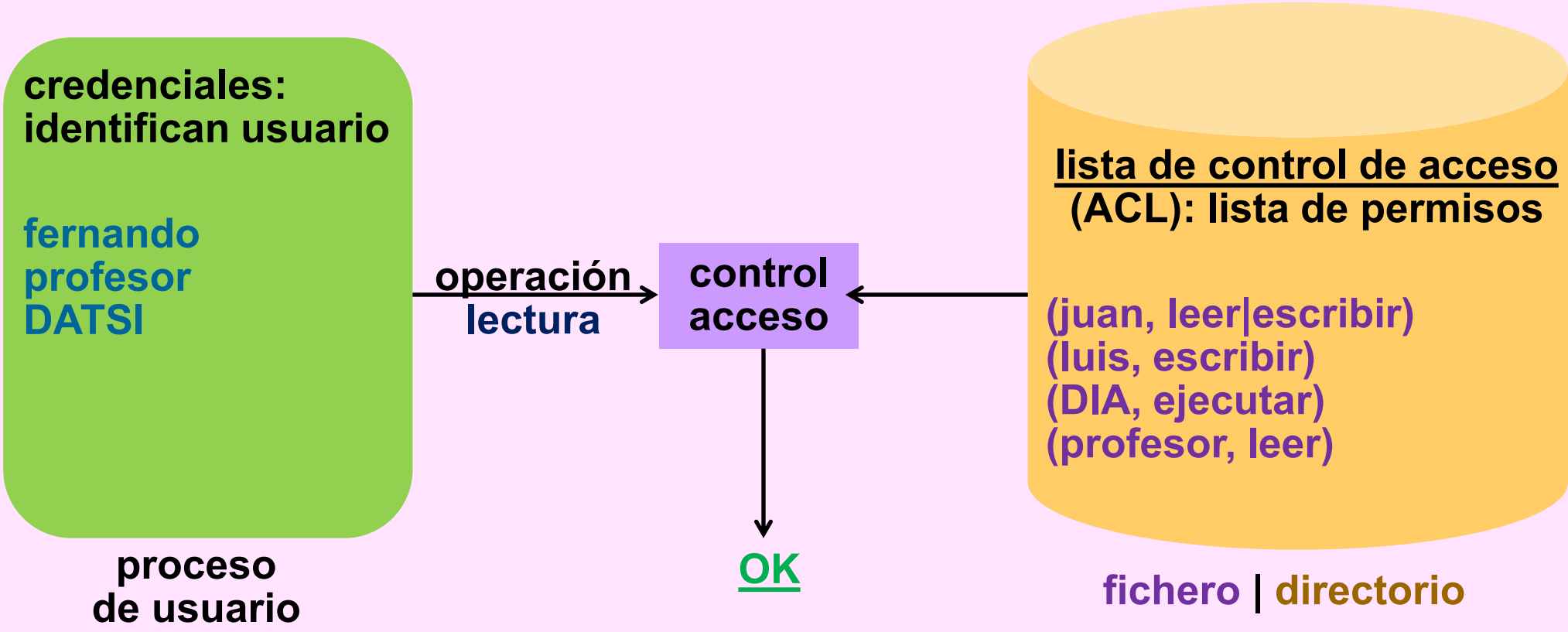
datsi © UPM 2022

POLITÉCNICA



CONTROL DE ACCESO DISCRECIONAL (DAC)

datsi © UPM 2022



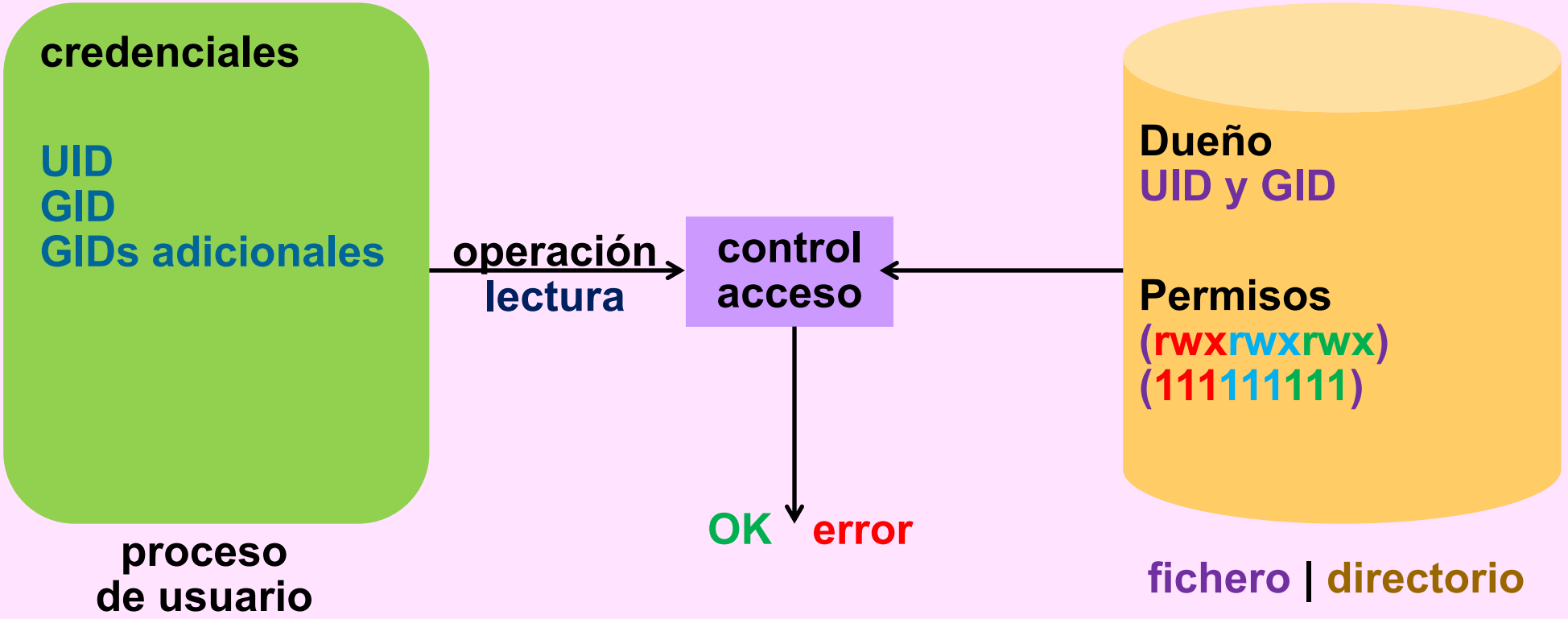
Alternativas a DAC que no estudiamos: MAC, RBAC…

DAC EN UNIX

datsi © UPM 2022

permisos → "ACL compacta" con solo 3 entradas:

- dueño (u): UID de dueño = UID del proceso
- grupo (g): GID del dueño ⊂ GIDs del proceso
- otros (o): resto de usuarios



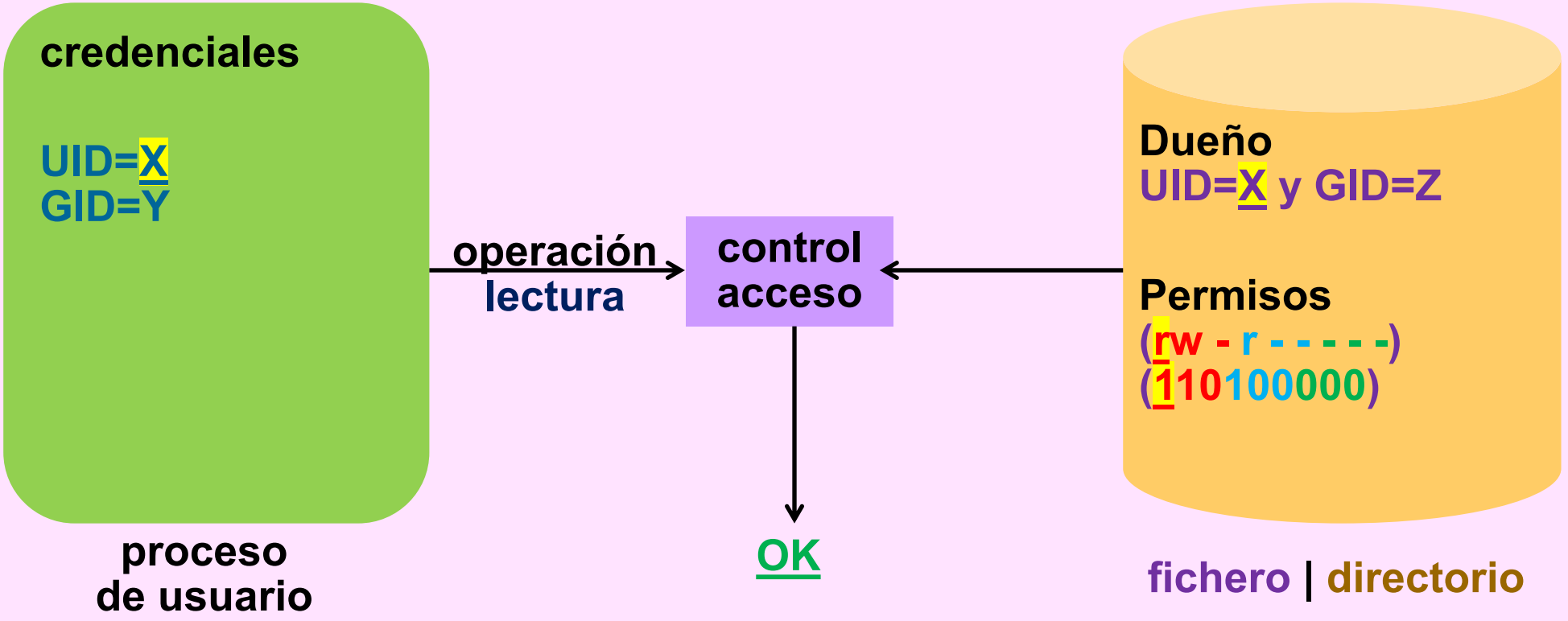
Y 3 operaciones por entrada (en total 9 bits):

- r: leer fichero; leer directorio
- w: escribir en fichero; añadir/eliminar entrada de directorio
- x: ejecutar fichero; usar una ruta que atraviesa directorio

DAC EN UNIX: ACCESO DE DUEÑO

datsi © UPM 2022

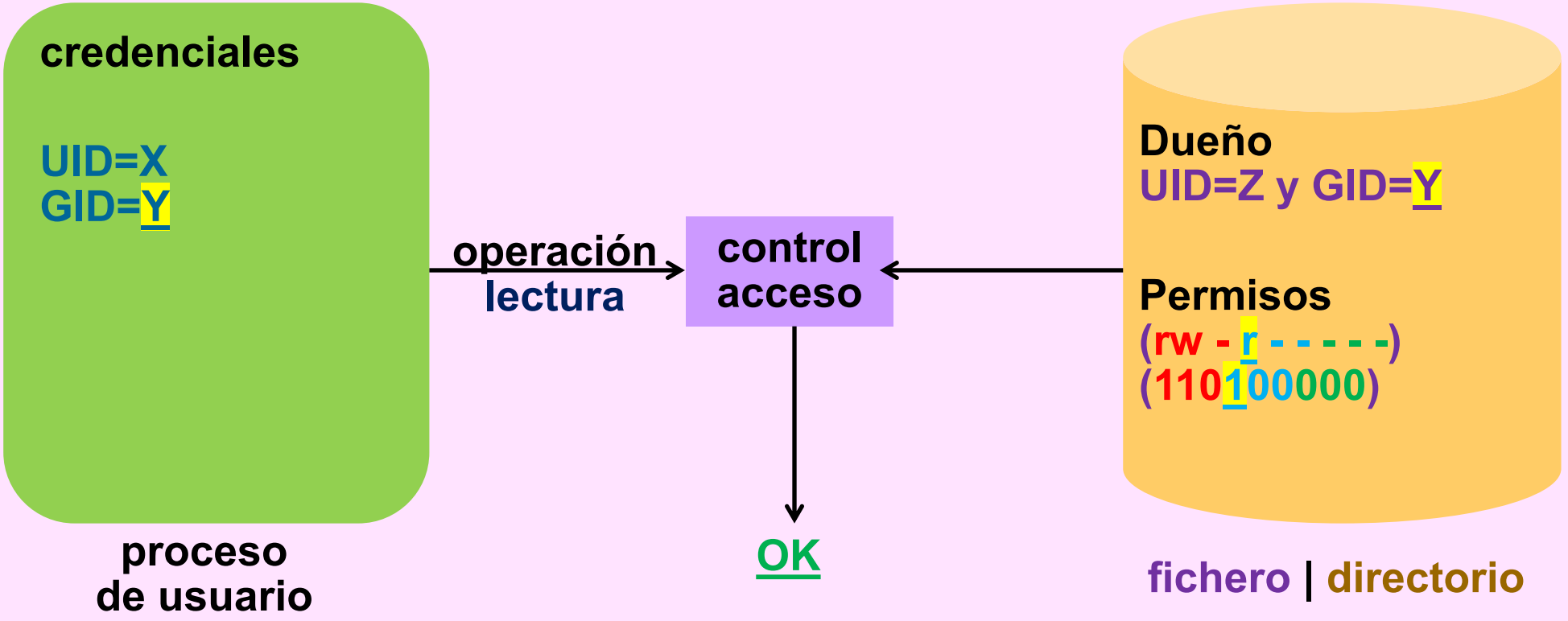
POLITÉCNICA



DAC EN UNIX: ACCESO DE USUARIO DEL MISMO GRUPO

datsi © UPM 2022

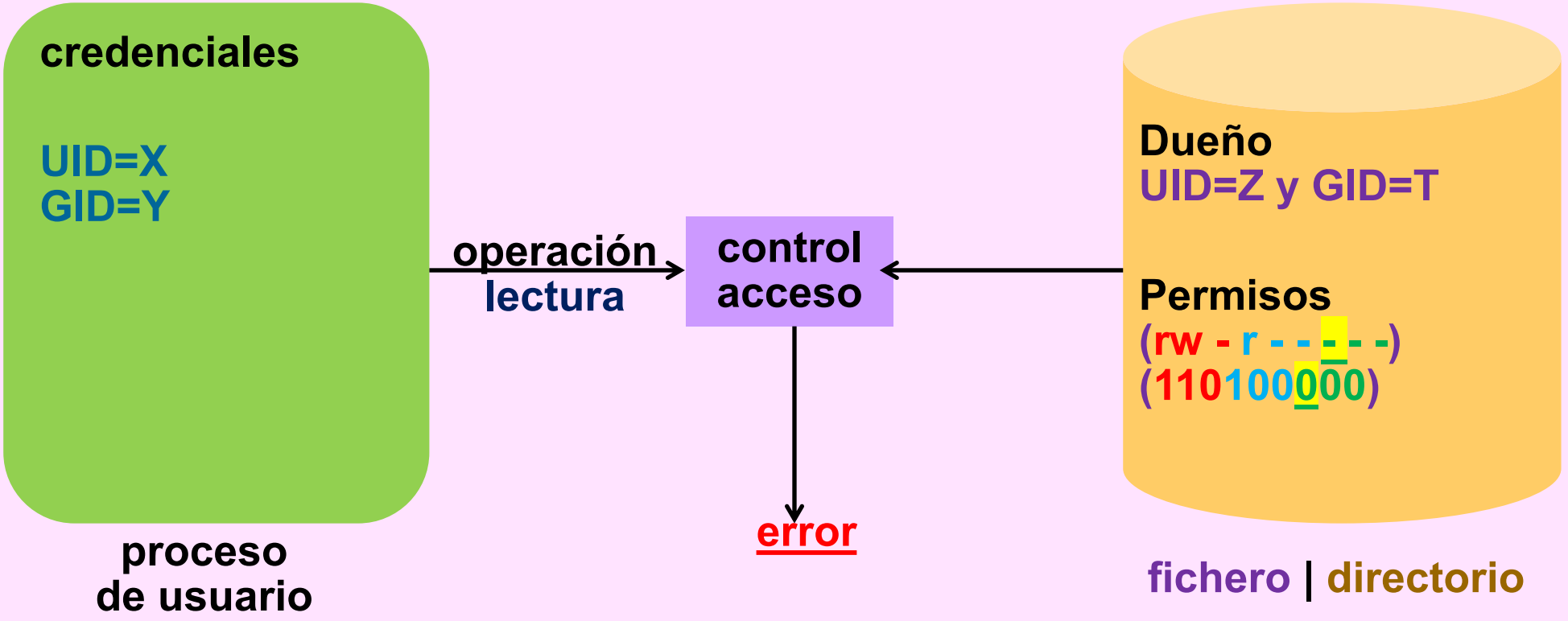
POLITÉCNICA



DAC EN UNIX: ACCESO DE USUARIO SIN RELACIÓN

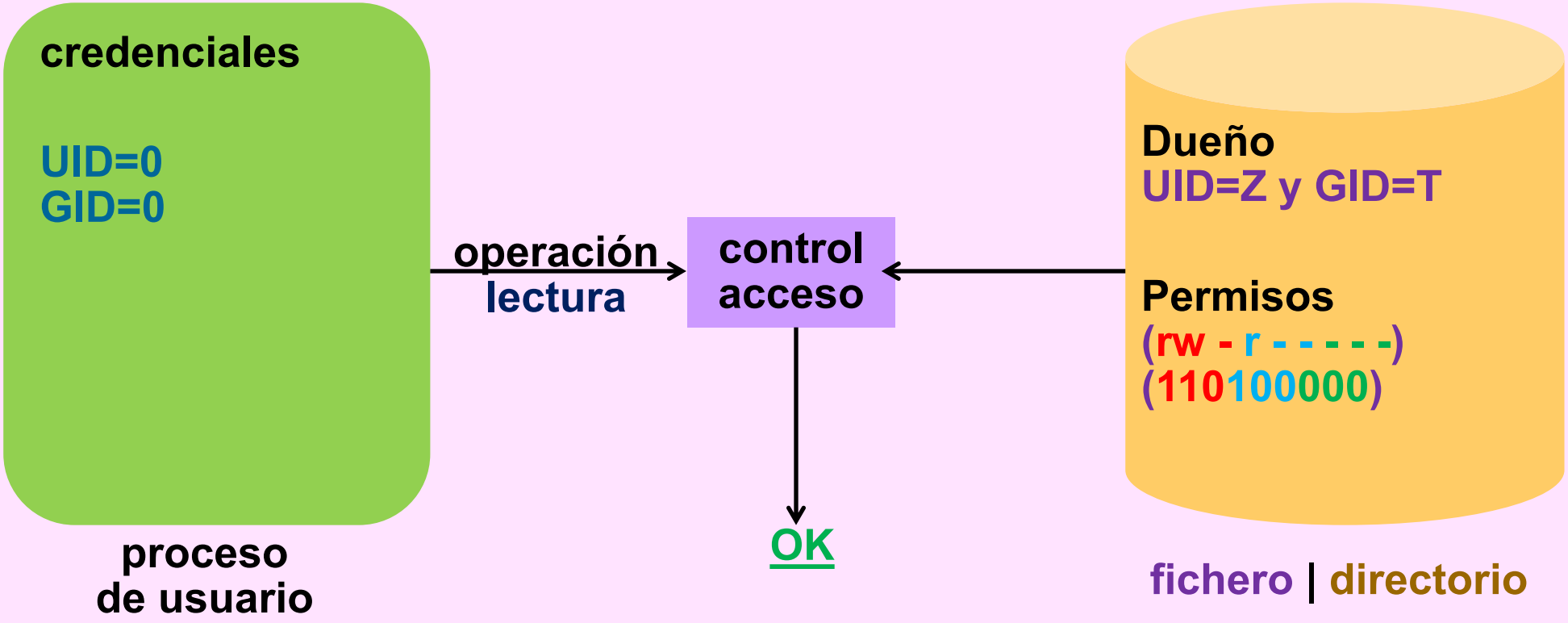
datsi © UPM 2022

POLITÉCNICA



DAC EN UNIX: ACCESO DE SUPER-USUARIO (ROOT)

datsi © UPM 2022



NECESIDAD DE CAMBIO DE IDENTIDAD EN UNIX

datsi © UPM 2022

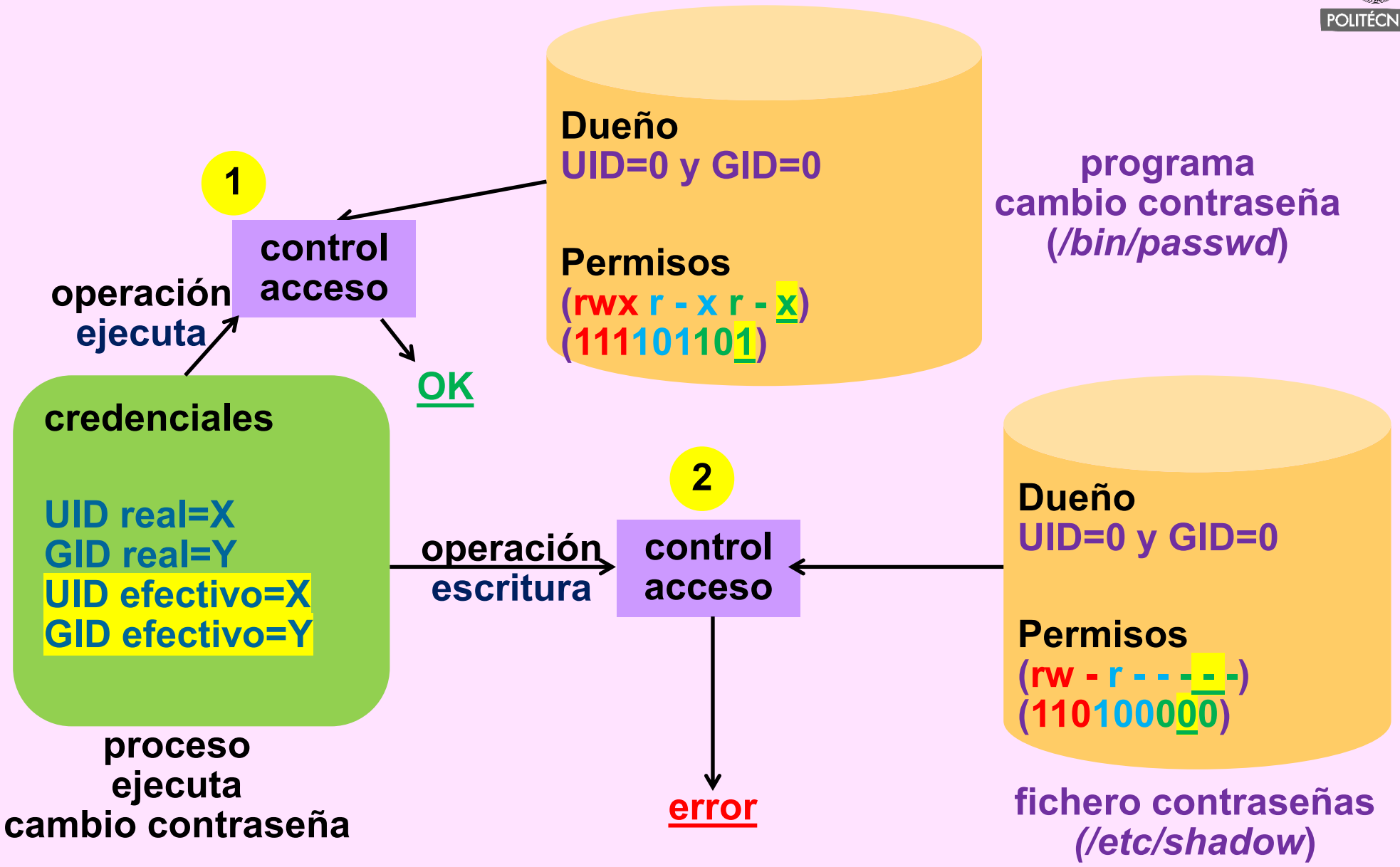
POLITÉCNICA

- **El problema del fichero de contraseñas *(/etc/shadow)*:**
  - **Solo el *root* debe poder accederlo: UID=GID=0 rw - r - - - - -**
  - **Pero usuario normal debe poder cambiar su contraseña**
  - **Proceso que ejecuta programa de cambio fallaría al escribir**
- **Mecanismo bit SETUID: asociado a fich. ejecutable (*/bin/passwd*)**
  - **Cuando proceso ejecuta ese programa:**
    - UID efectivo del proceso = UID del dueño del programa
- **Por cada proceso 2 UIDs: real y efectivo**
  - **real: el del usuario que creó el proceso**
  - **efectivo: el que se usa para validar los permisos**
    - Normalmente, UID efectivo = UID real
    - excepto si se ejecuta programa con SETUID:
      - » UID efectivo = UID del dueño del programa
- **Igual con bit SETGID (GID real y efectivo)**
- **Solución problema fichero de contraseñas:**
  - **Ese programa del *root* tiene SETUID activo**

DAC EN UNIX: SIN SUID ERROR ACTUALIZANDO CONTRASEÑA

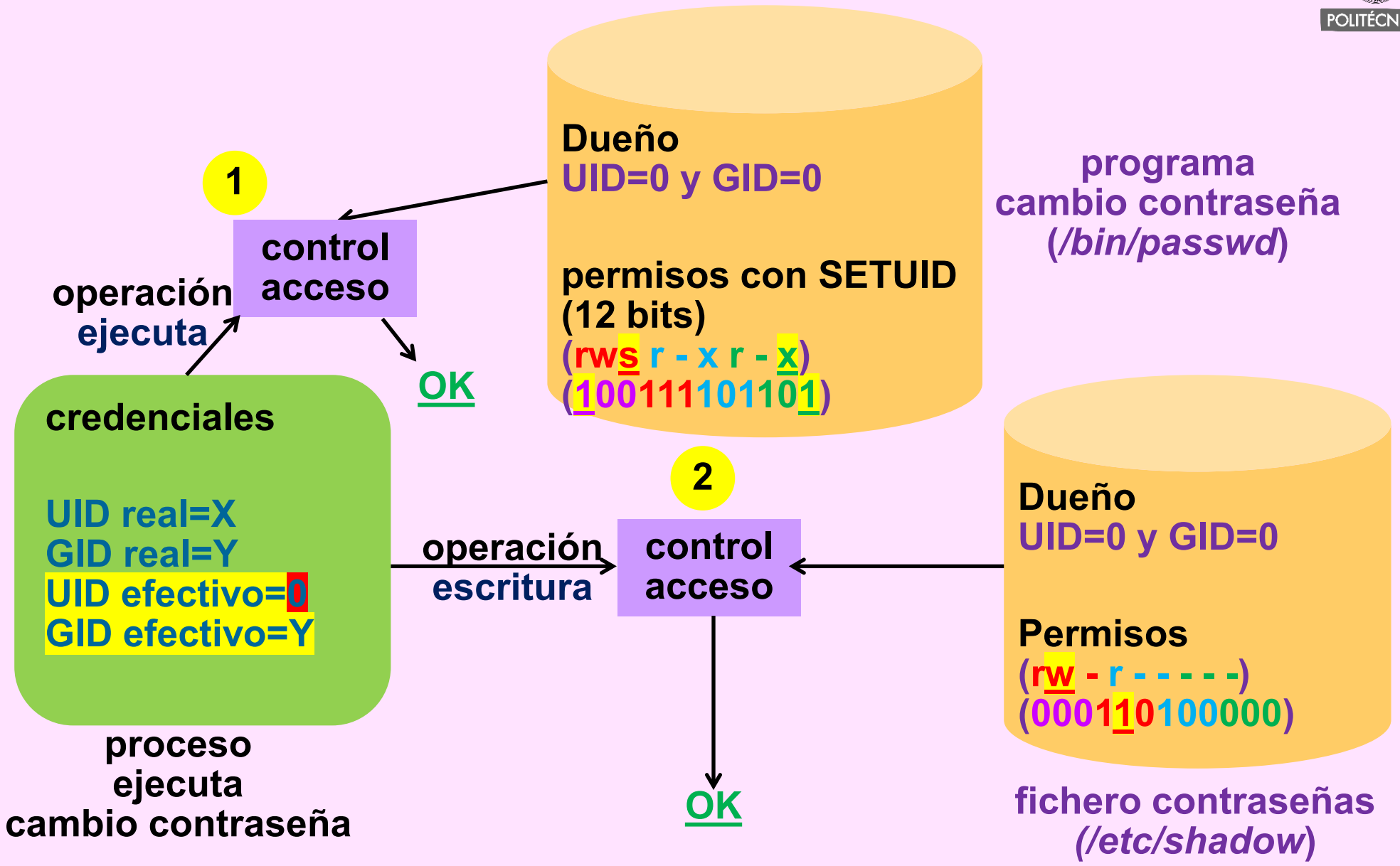
datsi © UPM 2022

POLITÉCNICA



DAC EN UNIX: CON USO DE SETUID FUNCIONAMIENTO CORRECTO

datsi © UPM 2022



PROBLEMA DE LOS DIRECTORIOS COMPARTIDOS (p.e. /tmp)

datsi © UPM 2022

POLITÉCNICA

- Recordatorio previo: proceso con permiso *w* en directorio
  - Puede crear ficheros en él y borrarlos aunque no suyos
- Directorio donde todos los usuarios pueden crear ficheros:
  - Permiso *w* para todos
    - UID=GID=0 rwxrwxrwx (000111111111)
- Pero permiso *w* también permite borrar todos los ficheros
  - Usuario puede borrar ficheros de otros usuarios
- Mecanismo bit STICKY: asociado a un directorio
  - Usuario solo puede borrar ficheros que sean suyos
    - UID=GID=0 rwxrwxrwt (001111111111)

SETUID | SETGID | STICKY

datsi © UPM 2022

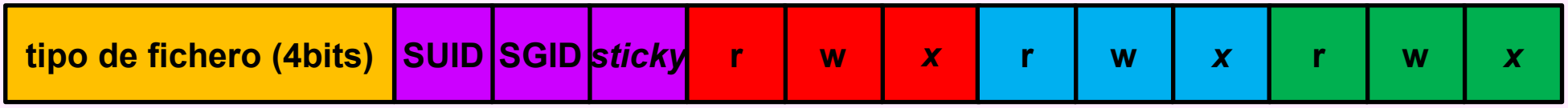
```
$ stat /bin/passwd
  Fichero: /bin/passwd
  Tamaño: 68208         Bloques: 136        Bloque E/S: 4096   fichero regular
Dispositivo: 805h/2053d Nodo-i: 275156      Enlaces: 1
Acceso: (4755/-rwsr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
Acceso: 2021-11-21 03:17:31.144055816 +0100
Modificación: 2021-07-15 00:08:18.000000000 +0200
      Cambio: 2021-10-12 11:21:31.582292215 +0200
    Creación: -
$ stat /usr/bin/crontab
  Fichero: /usr/bin/crontab
  Tamaño: 43720         Bloques: 88         Bloque E/S: 4096   fichero regular
Dispositivo: 805h/2053d Nodo-i: 265184      Enlaces: 1
Acceso: (2755/-rwxr-sr-x)  Uid: (    0/    root)   Gid: (  105/ crontab)
Acceso: 2024-09-18 02:28:36.109441563 +0200
Modificación: 2020-02-13 21:44:42.000000000 +0100
      Cambio: 2021-10-12 09:47:35.112001077 +0200
    Creación: -
$ stat /tmp
  Fichero: /tmp
  Tamaño: 4096          Bloques: 8          Bloque E/S: 4096   directorio
Dispositivo: 805h/2053d Nodo-i: 131077      Enlaces: 15
Acceso: (1777/drwxrwxrwt)  Uid: (    0/    root)   Gid: (    0/    root)
Acceso: 2024-09-23 23:11:40.802431473 +0200
Modificación: 2024-09-23 21:20:58.446482882 +0200
      Cambio: 2024-09-23 21:20:58.446482882 +0200
    Creación: -
```

TIPOS DE FICHEROS Y PERMISOS

datsi © UPM 2022

POLITÉCNICA

- Bits del 12 al 15: tipo de fichero
  - regular, directorio, enlace simbólico, FIFO, socket UNIX, disp caracteres o bloques
- Bit 11 (octal 04000): SETUID
- Bit 10 (octal 02000): SETGID
- Bit 9 (octal 01000): *sticky*
- Bit 8 (octal 00400): permiso de lectura para el dueño
- Bit 7 (octal 00200): permiso de escritura para el dueño
- Bit 6 (octal 00100): permiso de ejecución para el dueño
- Bit 5 (octal 00040): permiso de lectura para el grupo
- Bit 4 (octal 00020): permiso de escritura para el grupo
- Bit 3 (octal 00010): permiso de ejecución para el grupo
- Bit 2 (octal 00004): permiso de lectura para el resto
- Bit 1 (octal 00002): permiso de escritura para el resto
- Bit 0 (octal 00001): permiso de ejecución para el resto



16 bits